5.1 NotPetya et Maersk (2017)

L'incident NotPetya de juin 2017 offre un exemple net de propagation du risque au-delà de l'organisation initialement exposée. Le logiciel malveillant s'est diffusé à l'échelle internationale après avoir été introduit dans une chaîne de distribution logicielle utilisée en Ukraine. A. P. Moller-Maersk, groupe de transport maritime et de logistique, a confirmé que ses systèmes avaient été touchés et que ses activités avaient été perturbées. Dans son rapport annuel 2017, l'entreprise estime l'impact de l'attaque entre 250 et 300 millions de dollars, concentré sur Maersk Line (A. P. Moller-Maersk, 2018). Des récits journalistiques détaillés rapportent que la reconstruction du réseau a dépendu en partie d'une copie préservée presque par hasard d'un contrôleur de domaine (Greenberg, 2018).

La dépendance mobilisée est logicielle : la confiance accordée à un canal de mise à jour. L'intérêt du cas tient moins à l'ampleur des dommages informatiques qu'à la manière dont une compromission logicielle a atteint une entreprise dont les opérations reposent sur la coordination de systèmes numériques, d'installations portuaires, de flux de marchandises et de partenaires. La perturbation interne a gagné les opérations physiques, les clients et les partenaires commerciaux : un incident informatique est devenu un problème de continuité économique.

La dimension géopolitique est établie. Les autorités britanniques et américaines ont publiquement attribué NotPetya à l'armée russe le 15 février 2018 (The White House, 2018), et l'inculpation d'officiers du renseignement militaire russe en 2020 y a rattaché l'opération (U.S. Department of Justice, 2020). Le cas relève du niveau A. Il montre qu'une action menée dans un contexte régional peut produire des effets économiques bien au-delà de son théâtre initial.

Lecture par la grille : la dépendance est élevée, la concentration modérée (un logiciel répandu mais local), la substitution modérée (le logiciel comptable est lui-même remplaçable ; c'est la reconstruction du parc informatique, de l'ordre de quelques jours à quelques semaines selon les récits disponibles, qui a conditionné la reprise), la propagation élevée et la résilience faible, la reprise ayant tenu à des circonstances en partie fortuites. Pour l'organisation, l'enseignement est qu'elle doit être en mesure de contenir les effets d'une attaque qui ne la visait pas nécessairement en priorité.

Ce document sur **NotPetya et Maersk (2017)** constitue **la preuve parfaite et l'exemple canonique** de ce que vous cherchez à démontrer : **comment une cyberattaque conçue pour un conflit géopolitique régional produit des ravages à l'échelle mondiale, sur des cibles qui n'étaient même pas visées à l'origine.**

1. L'origine : Un conflit géopolitique strictement régional

L'attaque NotPetya s'inscrit initialement dans le contexte géopolitique des tensions militaires et politiques entre la Russie et l'Ukraine :

- **Cible visée à l'origine :** L'écosystème économique ukrainien. Le logiciel malveillant a été introduit via le canal de mise à jour d'un logiciel comptable (*M.E.Doc*) très utilisé en Ukraine.
- **Attribution étatique :** L'opération a été formellement attribuée à l'armée et au renseignement militaire russes par les autorités britanniques et américaines.

2. Le mécanisme de contagion : La chaîne d'approvisionnement (*Supply Chain*)

L'attaque s'est propagée hors des frontières ukrainiennes en exploitant la **dépendance logicielle et la confiance accordée aux canaux de mise à jour** :

- Il a suffi qu'une entreprise multinationale possède une filiale, un bureau ou simplement un partenariat commercial en Ukraine utilisant ce logiciel pour que l'infection pénètre l'ensemble de son réseau mondial.

3. L'impact mondial : Dommages collatéraux hors zone de conflit

Le cas du géant du transport maritime **A. P. Moller-Maersk** illustre l'effet de débordement mondial (*spillover*) :

- **Infection fortuite :** Maersk n'était pas la cible prioritaire ou stratégique de l'opération militaire russe, mais le malware s'est propagé automatiquement à ses systèmes mondiaux.
- **Passage du cyber au monde physique :** La paralysie des systèmes d'information a directement bloqué les opérations physiques : coordination des navires, gestion des installations portuaires, suivi des conteneurs et flux de marchandises mondiaux.

- **Coût économique massif :** L'impact pour Maersk seul s'est élevé entre **250 et 300 millions de dollars**, nécessitant la reconstruction quasi totale de son parc informatique mondial (qui n'a été sauvée que par une copie de sauvegarde conservée par hasard).

Synthèse pour votre démonstration

Ce cas apporte la conclusion idéale à votre argumentation :

Conclusion clé du document :

"Le cas montre qu'une action menée dans un contexte régional peut produire des effets économiques bien au-delà de son théâtre initial. Pour l'organisation, l'enseignement est qu'elle doit être en mesure de contenir les effets d'une attaque qui ne la visait pas nécessairement en priorité."

Tableau récapitulatif des enseignements de NotPetya

Dimension	**Fait démontré**
Géopolitique régionale	Cyberattaque étatique conçue pour déstabiliser un pays tiers (l'Ukraine).
Vecteur de transmission	Compromission d'une mise à jour logicielle locale (*Supply Chain*).
Cybersécurité mondiale	Propagation automatique non contrôlée à travers le réseau Internet global.

Conséquence économique	Paralysie de géants mondiaux neutres (Maersk, Saint-Gobain, Merck...) et rupture des chaînes logistiques physiques mondiales.

5.2 SolarWinds (2020)

La compromission de la plateforme de supervision Orion de SolarWinds, révélée en décembre 2020, illustre une autre forme de dépendance : celle qui repose sur la confiance accordée aux outils logiciels et à leurs mécanismes de mise à jour. Des versions légitimes du logiciel avaient été altérées pour y intégrer le code malveillant SUNBURST. Les mises à jour distribuées aux clients ont ainsi servi de vecteur d'intrusion. Selon l'éditeur, qui avait notifié environ 33 000 clients d'Orion, moins de 18 000 clients auraient installé une version contenant le code malveillant (SolarWinds Corporation, 2020). Le CERT-FR a documenté l'incident et recommandé aux organisations concernées de vérifier leurs versions, de rechercher des signes de compromission et de tenir compte du risque pesant sur les environnements administrés par la plateforme (CERT-FR, 2020). La CISA américaine a, de son côté, imposé aux agences fédérales la déconnexion des produits Orion concernés (CISA, 2020).

Le problème dépasse la vulnérabilité d'un produit. Un outil de supervision dispose d'une visibilité étendue sur les infrastructures qu'il administre. La confiance qui lui est accordée et les privilèges qui lui sont attribués en font un point d'entrée vers des ressources sensibles. Le cas montre que la conformité d'un fournisseur, la légitimité d'une mise à jour et la réputation d'un éditeur ne suffisent pas à garantir l'intégrité d'une chaîne logicielle : la relation de confiance est elle-même une composante du risque.

Les autorités américaines ont formellement attribué l'opération au service de renseignement extérieur russe (SVR) en avril 2021, en estimant que la compromission de la chaîne logicielle lui donnait la capacité d'espionner ou de perturber plus de 16 000 systèmes informatiques dans le monde (The White House, 2021 ; CISA, 2020) : niveau A.

Lecture par la grille : dépendance élevée, concentration élevée (une plateforme présente chez de très nombreux clients, avec des privilèges étendus), substitution élevée (remplacer un outil de supervision est un chantier de plusieurs mois), propagation élevée, résilience faible, la détection ayant été tardive. La sécurité d'une organisation ne peut pas reposer exclusivement sur la confiance accordée aux composants dont elle dépend.

Voici une synthèse affinée pour démontrer précisément **comment une crise géopolitique localisée dans une région donnée produit des conséquences systémiques sur la cybersécurité mondiale**, bien au-delà de la zone de conflit initiale.

La thèse centrale

Dans un monde numérique hyperconnecté, la géopolitique régionale ne reste jamais locale.

L'espace cyber ignorant les frontières physiques, une tension géopolitique ciblée sur une région devient instantanément un **risque global de cybersécurité** pour le reste du monde.

Cette contagion s'opère à travers **quatre mécanismes de propagation** :

1. L'effet de débordement technique (*Cyber Spillover*)

Lorsqu'un État déclenche des cyberattaques destructrices (malwares, essaims de rançongiciels, wiper) contre un pays voisin, le code malveillant se propage de manière incontrôlée sur Internet.

- **Propagation par contamination :** Un logiciel malveillant conçu pour paralyser une infrastructure régionale s'infiltre dans les réseaux des multinationales interconnectées à cette région.
- **Impact mondial :** Des entreprises situées à des milliers de kilomètres, neutres vis-à-vis du conflit, voient leurs systèmes chiffrés ou détruits simplement parce qu'elles partageaient une ligne de communication ou un serveur localisé dans la zone sous tension.

2. La déstabilisation de la chaîne d'approvisionnement mondiale (*Supply Chain*)

Comme illustré par le cas **SolarWinds**, la plupart des logiciels, composants et services cloud utilisés dans le monde proviennent de chaînes de valeur interconnectées.

- **Attaque du point de confiance :** Pour toucher une cible régionale ou un bloc adverse, un attaquant étatique peut compromettre un éditeur de logiciel ou un fabricant de matériel opérant à l'échelle mondiale.
- **Conséquence globale :** En empoisonnant une seule mise à jour logicielle ou en provoquant une pénurie sur un composant physique essentiel (puces, semi-conducteurs), c'est la sécurité et la continuité d'activité de dizaines de milliers d'entreprises mondiales qui sont compromises d'un coup.

3. La mondialisation des cyber-acteurs non-étatiques (*Proxies* & Hacktivistes)

Les tensions régionales agissent comme un catalyseur pour les groupes de cybercriminels et de mercenaires informatiques.

- **Multiplication des fronts :** Des collectifs hacktivistes se mobilisent à travers le globe pour soutenir l'un des belligérants. Leurs cibles ne se limitent pas à la zone de conflit, mais s'étendent aux alliés politiques, économiques et commerciaux des parties opposées.

- **Augmentation du bruit de fond criminel :** L'effondrement de la coopération policière internationale dans une région sous tension crée des zones de non-droit numériques. Les groupes cybercriminels y opèrent en toute impunité, intensifiant leurs attaques par rançongiciels contre le secteur privé mondial.

4. L'onde de choc réglementaire et la rupture de la confiance (*Splinternet*)

La géopolitique régionale oblige les États du monde entier à repenser leur dépendance stratégique vis-à-vis des technologies étrangères.

- **Perte de confiance dans les tiers :** Utiliser un logiciel, un composant ou un service cloud conçu dans un pays impliqué dans une crise régionale fait peser un risque immédiat d'espionnage, de porte dérobée (*backdoor*) ou de rupture de service.

- **Balkanisation du réseau :** En réaction, les gouvernements mondiaux imposent des restrictions d'exportation, des exigences de souveraineté renforcées (ex. directives NIS2) et un cloisonnement des données, morcelant le web global et complexifiant la cybersécurité des entreprises multionales.

En résumé

Événement géopolitique régional	**Mécanisme de transmission**	**Conséquence sur la cybersécurité mondiale**
Conflit armé / Cyberattaque ciblée	Propagation incontrôlée du code malveillant	Paralysie collatérale de réseaux d'entreprises neutres à travers le monde.

Pression / Sanctions / Blocus	Compromission des éditeurs et fournisseurs	Vulnérabilité massive de la chaîne d'approvisionnement logicielle et matérielle mondiale.
Tensions diplomatiques	Mobilisation de groupes *proxies* et hacktivistes	Augmentation globale des attaques par déni de service (DDoS) et fuites de données.
Rupture d'alliances	Durcissement des lois et contrôles à l'export	Obligation de refondre les architectures de sécurité et d'isoler les dépendances technologiques.

5.3 Le réseau électrique ukrainien (2015)

L'attaque de décembre 2015 contre des opérateurs de distribution d'électricité en Ukraine est un cas central pour comprendre les conséquences physiques d'une opération numérique. Les coupures ont touché environ 225 000 clients pendant plusieurs heures, jusqu'à environ six heures selon les analyses. Les attaquants, qui disposaient d'identifiants légitimes, ont pris le contrôle d'interfaces de commande pour provoquer les interruptions, puis ont effacé des systèmes au moyen du logiciel KillDisk, ce qui a compliqué la reprise à distance et obligé les opérateurs à passer en mode manuel (CISA, 2016 ; Lee et al., 2016).

Le cas met en évidence l'interdépendance entre systèmes d'information, technologies opérationnelles et fonctions essentielles d'un territoire. L'indisponibilité d'un système de contrôle ne se traduit pas seulement par une perte de données ou une interruption d'application : elle peut affecter directement la distribution d'une ressource indispensable. Les infrastructures civiles peuvent donc être visées dans un contexte de confrontation et devenir des instruments de pression stratégique.

Le niveau de preuve est A, sur la base de l'inculpation américaine de 2020, qui vise des officiers du renseignement militaire russe pour les attaques contre le réseau électrique ukrainien (U.S. Department of Justice, 2020). L'alerte publiée en 2016 décrit l'attaque et ses mécanismes sans, à notre connaissance, en désigner l'auteur (CISA, 2016) : l'attribution repose donc sur l'inculpation seule.

Lecture par la grille : dépendance élevée, concentration modérée (trois distributeurs aux architectures proches), substitution modérée (le courant a été rétabli en quelques heures grâce à la conduite manuelle, mais la remise en état des systèmes de contrôle numériques a été bien plus longue ; la conduite manuelle relève de la résilience, non de la substitution), propagation modérée, résilience partielle. Ce dernier point mérite d'être souligné : la durée relativement courte des interruptions tient aux procédures manuelles de reprise que les opérateurs avaient conservées. Protéger une infrastructure critique, c'est préserver sa capacité à fournir un service même lorsque ses systèmes numériques sont compromis.

Ce cas d'étude sur le **réseau électrique ukrainien (2015)** franchit un cap supplémentaire par rapport aux deux précédents : on passe de la dépendance économique ou logicielle à la **guerre hybride et à la déstabilisation d'un État**.

1. Sur le plan Géopolitique : La cyberattaque comme arme de guerre

Contrairement au cas *Change Healthcare* (cybercriminalité classique sans intention étatique avérée), ce cas illustre l'usage de la cyberattaque comme **instrument de pression stratégique et d'agression militaire** :

- **Cibler la population et l'économie :** La cyberattaque vise directement les infrastructures civiles (distribution d'électricité) pour semer le chaos, impacter la vie quotidienne de 225 000 citoyens et créer une instabilité politique.
- **L'attribution géopolitique :** Le document souligne que la responsabilité est attribuée à un acteur étatique (des officiers du renseignement militaire russe selon

l'inculpation américaine de 2020). La cyberdéfense devient alors indissociable de la défense nationale interarmées.

- **La doctrine de la guerre hybride :** Une opération numérique est utilisée en parallèle ou en amont de tensions géopolitiques plus larges pour affaiblir un pays cible sans déclencher immédiatement un conflit armé traditionnel.

2. Sur le plan de la Cybersécurité : L'impact sur le monde physique (OT / ICS)

Ce cas est emblématique car il montre la convergence entre l'informatique de gestion (IT) et les **systèmes industriels / technologies opérationnelles (OT)** :

- **Conséquences dans le monde réel :** L'indisponibilité du système numérique ne détruit pas seulement des données, elle prive les usagers d'une ressource vitale physique (l'électricité).

- **Sabotage du système de secours (KillDisk) :** Les attaquants ont effacé les systèmes de contrôle pour empêcher la reprise automatique ou à distance, forçant un retour au fonctionnement manuel.

- **La résilience par le "mode dégradé" :** Le point fondamental relevé par le texte est que la véritable sécurité d'une infrastructure critique repose sur sa capacité à continuer de fonctionner en **mode manuel / dégradé** lorsque le numérique est compromis.

Tableau comparatif des 3 cas d'étude

Cas	Nature du Risque	Acteur / Intention	Leçon principale
5.6 IA & Dépendances de calcul	Risque structurel / Dépendance technologique	États (régulation / souveraineté)	Vulnérabilité liée aux chaînes d'approvisionnement mondiales et au matériel.

5.4 Change Healthcare	Risque de concentration / Point unique de défaillance	Cybercriminels (lucratif)	Paralysie d'un secteur entier en frappant un seul prestataire central.
5.3 Réseau Électrique Ukrainien	Sabotage industriel / Attaque étatique ciblée	Acteur étatique (géopolitique / militaire)	Nécessité de préserver une capacité de fonctionnement manuel des infrastructures physiques.

Souhaitez-vous comparer ces cas sous l'angle des cadres réglementaires actuels (comme la directive NIS2) ?

5.4 Change Healthcare (2024)

La cyberattaque par rançongiciel subie par Change Healthcare en février 2024 montre les conséquences d'une forte dépendance à un intermédiaire numérique dans un secteur essentiel. Ce prestataire américain intervient notamment dans le traitement des paiements et des opérations administratives liées aux soins de santé. Selon le Government Accountability Office, l'attaque, qui a comporté un vol de données, a entraîné des pertes estimées à 874 millions de dollars et des répercussions étendues sur les prestataires de soins et sur la prise en charge des patients (U.S. GAO, 2024). Ce chiffre n'est qu'un instantané : la maison mère UnitedHealth Group fait état, pour l'exercice 2024, de coûts directs de réponse dépassant les deux milliards de dollars, hors pertes d'activité, et d'un programme de prêts aux prestataires de soins de plus de neuf milliards de dollars (UnitedHealth Group, 2025).

Ce cas révèle un risque de concentration. Lorsqu'un prestataire occupe une position centrale dans le fonctionnement d'un secteur, son indisponibilité peut toucher simultanément des organisations qui restent juridiquement et opérationnellement indépendantes. Chacune peut disposer de son propre dispositif de cybersécurité et se retrouver pourtant face au même point de défaillance.

L'impact systémique doit toutefois être distingué de l'intention stratégique. Il s'agit d'une attaque par rançongiciel, et aucun élément public ne la relie, à notre connaissance, à une stratégie étatique (U.S. GAO, 2024). Elle démontre les conséquences d'une dépendance centralisée, mais elle ne suffit pas à établir une opération de déstabilisation étatique : niveau C.

Lecture par la grille : dépendance élevée, concentration élevée, substitution élevée, propagation élevée, résilience faible. Le cas est précieux pour la proposition P2 : il produit un impact sectoriel considérable sans acteur étatique avéré.

Oui, tout à fait. Ce document sur l'attaque contre **Change Healthcare (2024)** illustre parfaitement ce qu'on appelle en cybersécurité un **risque de concentration** et un **point unique de défaillance (*Single Point of Failure*)**, deux notions qui ont de lourdes conséquences aussi bien en cybersécurité qu'en géopolitique.

1. Du point de vue de la Cybersécurité : Le piège de la concentration

Le texte montre un phénomène très répandu : même si chaque hôpital ou pharmacie gère bien sa propre sécurité informatique, tous dépendent du **même intermédiaire central** pour traiter leurs opérations et paiements.

- **Effet domino (propagation) :** En frappant une seule cible (l'intermédiaire), les cybercriminels ont paralysé tout un secteur d'activité (santé, paiements, soins aux patients).

- **L'illusion de l'autonomie :** Une organisation peut investir massivement dans sa propre sécurité, mais rester totalement vulnérable si le prestataire externe auquel elle est reliée s'effondre.

- **Coûts disproportionnés :** L'impact financier dépasse de loin le coût de l'attaque initiale (des milliards de dollars de pertes indirectes et de soutien financier d'urgence).

2. Du point de vue Géopolitique : Une vulnérabilité stratégique exploitable

Même si l'attaque de 2024 contre Change Healthcare était une cybercriminalité classique à but lucratif (rançongiciel) et non une attaque étatique, ce cas de figure révèle une **faiblesse majeure qu'un État rival pourrait exploiter en temps de crise** :

- **Mise en évidence des "goulots d'étranglement" (*Chokepoints*) :** Les adversaires étatiques étudient ces dépendances économiques et techniques. En cas de tensions géopolitiques ou de conflit (guerre hybride), attaquer un ou deux acteurs clés d'un pays ennemi permet de déstabiliser toute sa société sans avoir à cibler chaque entité individuellement.

- **Souveraineté et dépendance envers des acteurs étrangers :** Si une nation dépend entièrement de prestataires numériques concentrés (qu'ils soient sur son sol ou dans un pays tiers), sa sécurité nationale est conditionnée par la résilience de ces quelques entreprises privées.

- **Armement de la chaîne d'approvisionnement :** Ce type de dépendance montre qu'un acteur hostile n'a pas besoin de détruire une infrastructure critique physique (réseau électrique, barrages) pour semer le chaos ; bloquer les flux de données ou financiers d'un intermédiaire monopolistique suffit.

En résumé

Le texte montre que **la concentration des services numériques transforme la vulnérabilité d'un seul acteur privé en un risque systémique pour toute une nation**. C'est à la fois une faille majeure de cybersécurité et un levier de pression géopolitique redoutable en cas de conflit.

5.5 Les terres rares (2025)

La géopolitique des dépendances ne se limite pas aux logiciels et aux réseaux. Elle concerne aussi les matériaux et les composants nécessaires à la fabrication des technologies contemporaines. Selon l'Agence internationale de l'énergie, la Chine représentait en 2024 environ 60 % de la production minière mondiale des terres rares utilisées dans les aimants, 91 % de leur production raffinée et 94 % de la fabrication mondiale des aimants permanents frittés concernés (IEA, 2025). La dépendance stratégique ne résulte donc pas seulement de la disponibilité géologique, mais aussi de la concentration des capacités industrielles de transformation.

Les contrôles à l'exportation introduits par la Chine le 4 avril 2025 sur sept terres rares lourdes, leurs composés et les aimants correspondants ont montré les conséquences possibles de cette concentration. L'AIE indique que des constructeurs automobiles en Europe, aux États-Unis et ailleurs ont rencontré des difficultés d'approvisionnement, certains réduisant leur taux d'utilisation ou suspendant temporairement des usines. Des contrôles plus larges, annoncés le 9 octobre 2025, visent désormais aussi les pièces, composants et assemblages contenant des terres rares d'origine chinoise (IEA, 2025).

Ce cas n'est pas une cyberattaque. Il élargit pourtant l'analyse : une organisation peut disposer d'une infrastructure numérique correctement sécurisée et rester vulnérable à une décision extérieure qui coupe l'accès à un composant indispensable. Le niveau de preuve est D, puisque la perturbation résulte d'une décision publique.

Lecture par la grille : dépendance élevée, concentration élevée, substitution élevée, propagation élevée, résilience partielle, les entreprises concernées ayant pu, pour certaines, ajuster leur production sans l'interrompre complètement.

Une organisation peut avoir une infrastructure numérique bien sécurisée et rester vulnérable à une décision extérieure qui coupe l'accès à un composant indispensable. La cybersécurité ne protège alors que ce que l'organisation administre, alors que la **disponibilité** du matériel dépend de ressources hors de son périmètre. C'est la distinction entre périmètre technique et périmètre de dépendance (3.1).

Conséquences possibles (mon raisonnement)

1. Allongement de la durée de vie du matériel, donc plus de vulnérabilités. Si le renouvellement des équipements est retardé ou plus cher, les organisations gardent plus longtemps des équipements anciens, parfois sans correctifs de sécurité. C'est un risque classique des environnements industriels (OT).

2. Achats de dépannage moins sûrs. Face à une pénurie, on se tourne vers de nouveaux fournisseurs, des courtiers ou le marché gris. Les risques de composants contrefaits, altérés ou mal qualifiés augmentent, et la vérification de l'intégrité de la chaîne d'approvisionnement passe au second plan.

3. Pression sur les budgets. Si le matériel devient plus cher, le budget peut être réorienté vers la continuité d'approvisionnement au détriment de la sécurité.

4. Fragilité de la couche physique du numérique. Certains composants électromécaniques (moteurs, ventilateurs, alimentations, stockage) peuvent dépendre de ces matériaux selon les cas. Une pénurie peut affecter les pièces de rechange des centres de données et des systèmes industriels, donc la capacité à maintenir un service ou à le restaurer après un incident.

5. Contexte de tension plus large. L'article note que les menaces hybrides combinent coercition économique et cyber (2.2). Une restriction à l'exportation peut accompagner une hausse des opérations étatiques, ce qui augmente la **probabilité de ciblage** (le premier modulateur de la matrice 3.6).

Lecture avec la grille et la matrice

- Catégorie **matérielle**, niveau de preuve **D** (décision publique, pas d'attribution cyber).
- Dépendance, concentration, substitution et propagation élevées, résilience partielle.
- Dans la matrice, c'est le cas où l'exposition structurelle est forte alors que l'activation géopolitique reste à documenter. La priorité vient donc surtout de la **structure** de la dépendance (la proposition P2), pas de l'identité d'un attaquant.

Réponses concrètes pour un RSSI

- Cartographier les équipements critiques dont la chaîne d'approvisionnement passe par ces composants.
- Constituer des stocks de pièces de rechange pour les fonctions essentielles.
- Prévoir des **mesures compensatoires** (segmentation, surveillance renforcée) pour le matériel obsolète conservé.
- Qualifier à l'avance des fournisseurs alternatifs, avant la crise.
- Tester le fonctionnement en mode dégradé (7.3).

Si vous voulez intégrer ce point à l'article, je peux ajouter un paragraphe à la fin de la section 5.5, ou un encadré dans la 3.6 sur les dépendances matérielles. Je veillerais à le formuler comme une interprétation de l'auteur, comme le reste du texte.

5.6 L'intelligence artificielle et les dépendances de calcul (cas prospectif)

Le développement de systèmes d'IA avancés repose sur des ressources interdépendantes : semi-conducteurs spécialisés, infrastructures de calcul, centres de données, énergie, données d'entraînement, modèles, compétences scientifiques et services d'informatique en nuage. Leur maîtrise est inégalement répartie entre États et acteurs industriels. Une organisation peut posséder ses données et définir ses politiques de sécurité tout en dépendant d'un fournisseur extérieur pour accéder à un modèle, exécuter des traitements ou maintenir un service essentiel.

L'IA transforme aussi le paysage des menaces. L'ENISA observe un recours croissant à l'IA par des groupes malveillants, principalement pour faciliter ou amplifier leurs activités, et note que l'intégration de systèmes d'IA dans les environnements professionnels élargit la surface d'attaque : ces systèmes sont à la fois des outils et des cibles (ENISA, 2025 ; ENISA, 2026b). Le NIST a par ailleurs formalisé les catégories d'attaques contre les systèmes d'apprentissage automatique : évasion, empoisonnement et atteintes à la confidentialité pour l'IA prédictive, auxquelles s'ajoutent, pour l'IA générative, les attaques sur la chaîne d'approvisionnement, l'injection d'instructions et les détournements d'usage (Vassilev et al., 2025). Les restrictions à l'exportation de technologies de calcul avancé montrent enfin que les composants nécessaires à l'IA sont devenus des instruments de politique de sécurité nationale. Le cadre dit de diffusion de l'IA, publié en janvier 2025 (U.S. Department of Commerce / BIS, 2025), a toutefois fait l'objet d'une annonce d'abrogation par le BIS en mai 2025, avant son entrée en application, et son remplacement n'était toujours pas publié à la mi-2026, les contrôles antérieurs sur les puces avancées demeurant en vigueur (Miller & Chevalier, 2026). Cette instabilité illustre elle-même le caractère mouvant de ces leviers.

Ce cas diffère des précédents : il ne s'appuie pas sur un incident documenté de perturbation massive. Il est retenu parce que la structure de dépendance y est visible avant toute crise, ce qui permet d'éprouver la grille de manière préventive. La question devient : de quoi dépend notre IA ? Modèle, nuage, données, interfaces de programmation, infrastructure, éditeur, processeurs graphiques, chaîne logicielle. Une indisponibilité de quarante-huit heures d'un fournisseur de modèle serait-elle supportable pour les fonctions qui s'appuient sur lui ?

Lecture par la grille : le codage est indicatif : dépendance modérée à élevée selon les organisations, concentration élevée, substitution élevée, propagation modérée, résilience à documenter. Le niveau de preuve est D, pour la couche de calcul.

Le lien entre géopolitique et cybersécurité de l'IA

Le texte présenté met en lumière une imbrication forte entre la géopolitique des technologies et la cybersécurité. Les choix géopolitiques influencent directement la structure des risques numériques et la résilience des organisations.

1. La dimension géopolitique : Les dépendances de calcul

- **Une ressource stratégique concentrée :** Le développement des systèmes d'IA repose sur des chaînes d'approvisionnement hautement interdépendantes (semi-conducteurs spécialisés, centres de données, énergie, modèles de pointe).

Leur maîtrise est inégalement répartie entre les États et les acteurs industriels.

- **L'arme des restrictions technologiques :** Les restrictions à l'exportation de technologies de calcul avancé montrent que les composants de l'IA sont devenus de véritables **instruments de politique de sécurité nationale**. L'instabilité réglementaire (comme l'évolution des cadres de contrôle des puces avancées par les autorités) fragilise la prévisibilité des chaînes d'approvisionnement mondiales.

2. Conséquences directes sur la cybersécurité

- **Élargissement de la surface d'attaque :** L'intégration de l'IA dans les environnements professionnels fait de ces systèmes à la fois des **outils** utilisés par des groupes malveillants pour amplifier leurs attaques (relevé par l'ENISA) et des **cibles** critiques à protéger.

- **Diversification des vulnérabilités (classification NIST) :**

    - *IA prédictive :* Risques d'évasion, d'empoisonnement des données d'entraînement et d'atteintes à la confidentialité.

    - *IA générative :* Menaces sur la chaîne d'approvisionnement logicielle, injection d'instructions et détournements d'usage.

- **Risque systémique de dépendance :** La dépendance structurelle vis-à-vis d'un fournisseur tiers (pour l'accès aux modèles ou aux infrastructures cloud) crée un point de vulnérabilité unique. Une défaillance ou une indisponibilité prolongée de ces fournisseurs expose l'ensemble des processus opérationnels qui s'y appuient.

Quelles approches privilégiez-vous pour auditer la résilience de vos architectures face à ces dépendances technologiques croissantes ?

Voici comment cet enjeu géopolitique et de cybersécurité s'articule selon le point de vue des trois grands blocs :

1. Le point de vue des États-Unis (USA) : *Garder l'avance et fermer le jeu*

Les États-Unis sont aujourd'hui en position de force sur la majorité de la chaîne (conception des puces comme Nvidia, géants du cloud comme AWS/Microsoft/Google, et modèles majeurs).

- **Enjeu géopolitique :** Maintenir leur suprématie technologique et empêcher leurs rivaux (principalement la Chine) d'accéder aux technologies de calcul de pointe. Cela se traduit par des régulations et des contrôles à l'exportation stricts sur les puces et les équipements.

- **Impact cybersécurité :**

    - **Protection du secret industriel :** Risque élevé d'espionnage économique et de cyberattaques étatiques visant à voler leur propriété intellectuelle (puces, architecture de modèles).

    - **Sécurisation de la chaîne d'approvisionnement :** Volonté de rapatrier la fabrication (via le *Chips Act*) pour éviter de dépendre d'usines vulnérables en Asie (notamment à Taïwan).

2. Le point de vue de la Chine : *Atteindre l'autonomie et contourner les blocus*

La Chine fait face à des restrictions d'accès aux processeurs les plus puissants sous l'impulsion américaine.

- **Enjeu géopolitique :** Viser l'autonomie stratégique complète en développant ses propres puces, infrastructures de calcul et modèles d'IA souverains pour ne plus dépendre des technologies américaines.

- **Impact cybersécurité :**

    - **Contournement et renseignement :** Recours accru à la recherche souveraine, mais aussi au cyberespionnage pour combler le retard technologique.

    - **Risques de failles sur le matériel alternatif :** L'utilisation de puces ou de logiciels développés en urgence pour remplacer les standards américains peut introduire de nouvelles vulnérabilités ou failles de sécurité non détectées.

3. Le point de vue de l'Europe : *Subir la dépendance et tenter de réguler*

L'Europe dispose de talents et de laboratoires de recherche, mais dépend très fortement des puces américaines/asiatiques et du cloud américain pour exécuter l'IA à grande échelle.

- **Enjeu géopolitique :** Trouver une voie de souveraineté numérique pour éviter de devenir un simple "terrain de jeu" ou un client captif des géants américains et chinois.

- **Impact cybersécurité :**

    - **Risque de rupture ou de pression politique :** Si un fournisseur américain coupe l'accès à ses serveurs ou modèles pendant 48 heures (ou en cas de conflit réglementaire/sanction), les entreprises européennes se retrouvent paralysées.

    - **Stratégie par la conformité et la sécurité :** Mise en place de réglementations strictes (IA Act, NIS2, RGPD) et d'évaluations de risques (comme les travaux de l'ENISA cités dans le document) pour forcer les éditeurs à sécuriser leurs chaînes d'approvisionnement et à garantir la résilience des systèmes.

En résumé

Bloc	**Position géopolitique**	**Priorité en Cybersécurité**
USA	Dominant / Protecteur	Protéger la propriété intellectuelle et contrôler la diffusion
Chine	Challenger / En quête d'autonomie	Développer des alternatives souveraines et contourner les blocus
Europe	Dépendant / Régulateur	Gérer le risque de rupture de service et sécuriser les usages